CS851: Network Security

Assignment 1 Lab Report

Submitted by

SAMYAK SHRIRAM GEDAM

Roll No: 252IS032

II Semester M-Tech CSIS

Department of Computer Science and Engineering
National Institute of Technology Karnataka
Surathkal, Mangalore-575025, India

2025–2026

Task 1: System Profiling

Parameter	Details
Operating System and version	Windows 10 Home Single Language (Version 22H2) (OS Build 19045.6466)
User privilege level	Administrator
Installed security tools	Microsoft Defender Antivirus, Windows Firewall
Disk Encryption Status	Bitlocker is Off
Patch Management	Automatic Windows Updates Enabled
Primary Applications	Web Browser (Chrome), Messaging, Development Tools (VS Code)
Internet usage pattern	Emails, Web browsing, Software downloads (PDFs, IDEs, etc), Youtube, Cloud usage (Google Drive, GitHub)

Table 1: System Profile Table

Figure 1: Operating System and version

Figure 2: User Privileges

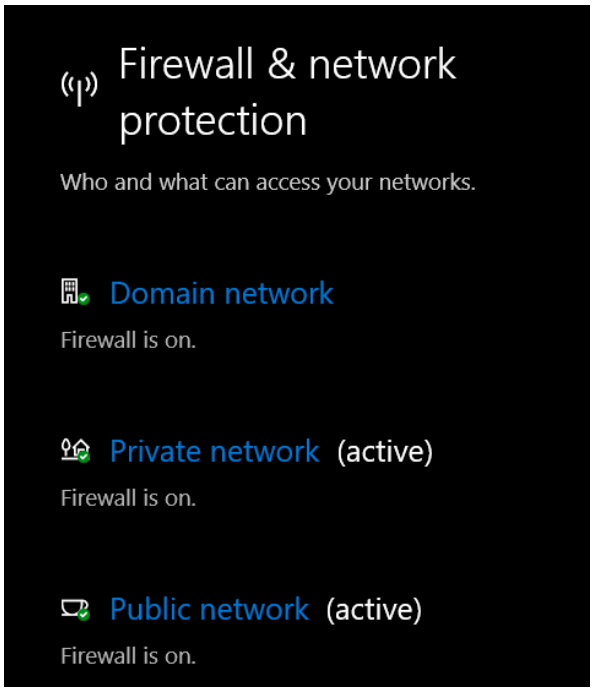

Figure 3: Firewall Status

Figure 4: Disk Encryption Status

Task 2: ATT&CK Tactic Selection

This task identifies relevant adversary tactics from the MITRE ATT&CK Enterprise framework. The tactics are selected that reflect the most likely lifecycle of an attack, from the moment a threat enters the system to the point where data is stolen or the system is damaged.

1. **Initial Access (TA0001)**: Personal PCs are frequently targeted through phishing emails, malicious downloads and USBs. Since the system is regularly used for email, web browsing, and software downloads, these activities makes it vuknerable.

2. **Execution (TA0002)**: This covers how the adversary runs malicious code, such as opening a malicious .exe file or a script after a download. Since the system allows standard application execution without whitelisting, adversaries can run malicious payloads once access is obtained.

3. **Persistence (TA0003)**: Attackers want to stay on your system even after a reboot. On

Windows, this is often done via "Startup folders", "Registry Run keys." or or background services that survive reboots.

4. **Privilege Escalation (TA0004)**: SInce User account has full Admin rights, and user log in as Administrator, an attacker can easily gain full control to disable security software or install deep-level malware.

5. **Defense Evasion (TA0005)**: Although antivirus and firewall protections are enabled, advanced malware can attempt to evade detection by disabling security features, or hiding within trusted processes. Threats may bypass Defender/Firewall. Adversaries will try to hide their presence by disabling Windows Defender.

6. **Credential Access (TA0006)**: Personal PCs store high-value targets like browser-saved passwords.

7. **Command and Control (TA0011)**: Once infected, the system usually communicates with an external server to receive instructions or "phone home."

8. **Exfiltration (TA0010)**: The ultimate goal of most attacks is to steal private documents, photos, or financial data and upload them to the attacker's server.

9. **Impact (TA0040)**: An attacker could encrypt files (ransomware), corrupt system data, or degrade system performance, directly affecting availability and usability.

Task 3: Technique-Level Analysis

Now, we will dive deeper into the tactics we selected. For each tactic, we identify specific techniques—the actual "how-to" of an attack—and evaluate how Windows PC stands against them.

Tactic	**Tech. ID**	**Technique Name**	**Threat factor**	**Current Visibility/ Defense**	**Risk**
Initial Access	T1566	Phishing	Malicious emails.	Low (Hard to distinguish from legitimate user email)	High
	T1204	User Execution	Running a malicious .exe or .scr file.	Medium (Visible in SmartScreen logs if enabled)	High
	T1190	Exploit Public-Facing App	Exploiting a vulnerability in a web server/app.	Medium (Firewall logs may show blocked attempts)	Low
Execution	T1059	Command/ Scripting	Running malicious PowerShell/CMD scripts.	Medium (PowerShell Script Block Logging)	Med
	T1203	Exploitation for Client	Exploiting bugs in PDF readers or Office.	Low (Hard to detect memory-based exploits)	Med
	T1053	Scheduled Task	Using Windows Task Scheduler to run code.	High (Easily seen in Task Scheduler or Event Viewer)	Med

Tactic	Tech. ID	Technique Name	Potential Use Case	Current Visibility/ Defense	Risk
Persistence	T1547.001	Registry Run Keys	Adding malware to the Startup Registry.	High (Visible in Task Manager 'Startup' or Autoruns)	Med
	T1543.003	Windows Service	Creating a malicious background service.	High (Visible in Services.msc and system logs)	Med
	T1137	Office Start-up	Using malicious Word/Excel macros/ add-ins.	Low (Often missed by users; hidden in AppData)	High
Privilege Esc.	T1068	Exploitation for Priv.	Using a kernel exploit to get SYSTEM.	Low (Exploits often happen before logging starts)	Low
	T1548.002	Bypass UAC	Silently elevating to Admin without prompt.	Medium (prompts are visible, but bypasses are silent)	Med
	T1053.005	Scheduled Task	Running a task with "Highest Privileges."	Medium (Requires checking 'Run with highest privileges')	Med
Defense Evasion	T1562.001	Disable/ Modify Tools	Turning off Windows Defender/Firewall.	High (Windows Defender notifies of Tamper events)	Med
	T1070.004	File Deletion	Deleting logs or malware files after use.	Low (Standard file deletion isn't tracked by default)	Med
	T1027	Obfuscation	Hiding code inside scripts to bypass AV.	Low (Signature-based detection often fails here)	High
Credential Acc.	T1555.003	Credentials from Browser	Stealing Chrome/ Edge saved passwords.	Low (Malware can read local profile files silently)	High
	T1003.001	LSASS Memory	Dumping RAM to steal Windows login hashes.	Medium (Credential Guard/Defender flags memory access)	Med
	T1056.001	Keylogging	Recording keystrokes to steal bank logins.	Low (Hard to detect unless AV catches the process)	High
Command & Ctrl	T1071.001	Web Protocols	Using HTTPS to talk to an attacker server.	Low (HTTPS traffic looks like normal web browsing)	High
	T1105	Ingress Tool Transfer	Downloading more tools from the internet.	Medium (Defender scans newly downloaded files)	Med
	T1090	Proxy	Routing malicious traffic through a proxy.	Medium (Visible in Windows Proxy/Network settings)	Med

Tactic	Tech. ID	Technique Name	Potential Use Case	Current Visibility/ Defense	Risk
Exfiltration	T1041	Over C2 Channel	Sending data out via the active C2 link.	Low (Outbound traffic is rarely filtered on home PCs)	High
	T1567	Via Web Service	Uploading files to Dropbox/Mega/ GitHub.	Low (Uploads to Cloud storage look like user activity)	High
	T1048	Over Alternative Port	Using non-standard ports to bypass firewalls.	Medium (Visible in network monitoring tools if active)	Med

Observations

- Visibility Gaps: Credential Access and Exfiltration have mostly "Low" visibility. This is because standard Windows setups don't monitor what files are being sent out to the internet or what is happening inside the browser's local storage.
- Visibility Strengths: Persistence and Defense Evasion have higher visibility because Windows provides dedicated tools (Task Manager, Services, Windows Security) to monitor these changes.

Task 4: ATT&CK Coverage Matrix

The objective of this task is to visualize the security posture by combining Detection Capability, Prevention Capability, and Overall Risk. This "Heat-map" approach helps identify exactly where the defenses are strongest and where they are failing.

ATT&CK Tactic	Detection	Prevention	Overall Risk
Initial Access (TA0001)	Medium	Low	High
Execution (TA0002)	Medium	Medium	Medium
Persistence (TA0003)	High	Medium	Low
Privilege Escalation (TA0004)	Medium	High	Low
Defense Evasion (TA0005)	Medium	Medium	Medium
Credential Access (TA0006)	Low	Low	Critical
Command and Control (TA0011)	Low	Low	High
Exfiltration (TA0010)	Low	Low	High
Impact (TA0040)	Low	Low	High

Task 5: Security Gap Identification

This task involves a critical analysis of where your personal Windows machine is most vulnerable based on the mapping we've done so far.

Top Five Security Gaps

1. **Credential Exposure in Browsers**: Most browsers store passwords in local files that are easily accessible to malware. Without a "Master Password" or hardware-backed encryption, an attacker can dump all saved credentials silently.

2. **Lack of Outbound Traffic Monitoring**: While the Windows Firewall blocks incoming connections, it rarely alerts you when a local process starts sending large amounts of data to an unknown IP (Exfiltration).

3. **The "Admin by Default" Trap**: If your daily user account has Administrator privileges, any malware you accidentally execute inherits those same permissions, bypassing the need for a separate "Privilege Escalation" step.

4. **Insufficient Script Monitoring**: While Windows Defender scans scripts, sophisticated attackers use "obfuscation" (hiding code) or "Living off the Land" techniques (using powershell.exe for malicious tasks) which often fly under the radar.

5. **User-Driven Initial Access**: The system relies heavily on the user to identify phishing or malicious files. There is a lack of "sandboxing" for daily activities like opening email attachments or running new downloads.

Most Likely Attack Path

The most probable path for an adversary attacking your personal machine would be:

- **Step 1: Initial Access (T1566 - Phishing)**: You receive a convincing email or download a software "crack/repack" that contains a hidden payload.
- **Step 2: Execution (T1204 - User Execution)**: You run the file, and since you are an Admin, you click "Yes" on the UAC prompt.
- **Step 3: Persistence (T1547.001 - Registry Run Keys)**: The malware adds itself to the Windows Registry to ensure it stays active after you reboot.
- **Step 4: Credential Access (T1555.003 - Credentials from Browsers)**: The malware quietly copies your Chrome/Edge login database and sends it to the attacker.
- **Step 5: Exfiltration (T1041 - Over C2 Channel)**: Your private data is uploaded via HTTPS, appearing as normal web traffic to the system.

Highest-Risk ATT&CK Tactic

The highest-risk tactic is **Credential Access (TA0006)**.

Reasoning: Unlike a virus that deletes files (which is loud and easily detected), credential theft is silent. Once an attacker has your primary email or banking passwords, the "impact" moves from your computer to your entire digital identity, which is much harder to recover from than simply reinstalling Windows.

Task 6: Mitigation and Hardening Plan

This task focuses on proposing specific security controls to address the gaps identified in Task 5. Each control is mapped to a specific MITRE ATT&CK tactic to show how it reduces your overall risk.

Proposed Control	**MITRE Tactic Mitigated**	**Implementation Detail**
Principle of Least Privilege (PoLP)	Privilege Escalation (TA0004)	Create a "Standard User" account for daily tasks and only use the "Admin" account when installing trusted software.
Application Whitelisting / Control	Execution (TA0002)	Enable Windows "App Control for Business" or use "Smart App Control" to prevent unsigned or untrusted executables from running.
Browser Security Hardening	Credential Access (TA0006)	Use a dedicated Password Manager (like Bitwarden) instead of browser-based storage, and enable a "Master Password" for the browser.
Enhanced Logging (Sysmon)	Defense Evasion (TA0005)	Install Microsoft Sysmon to provide deep visibility into process creations, network connections, and file changes that standard logs miss.
Network Egress Filtering	Exfiltration (TA0010)	Configure Windows Defender Firewall to "Block by Default" for outbound connections, or use a tool like GlassWire to monitor and approve outbound traffic.
Multi-Factor Authentication (MFA)	Initial Access (TA0001)	Enable Hardware-based MFA (FIDO2) or App-based TOTP for all web services to ensure stolen credentials cannot be used for access.
Automated Offline Backups	Impact (TA0040)	Implement the 3-2-1 backup rule with at least one "Air-gapped" (offline) backup to protect against Ransomware or total system wipe.

Implementation Strategy

- **Immediate (High Impact/Low Effort)**: Switch to a Standard User account and move passwords out of the browser.
- **Short-term**: Configure Sysmon to feed better data into your Event Viewer for future security analysis.
- **Long-term**: Move toward a "Zero Trust" model on your network by strictly controlling which applications are allowed to communicate with the internet.

Conclusion

By mapping the personal Windows machine to the MITRE ATT&CK Enterprise Framework, we have moved from a reactive security posture to a proactive one. You we understand not just that we could be attacked, but exactly how and where our current visibility is lacking.